Technical Report

Designing a Safe Evidence-Preservation Workflow for a Hypothetical Compromised Laptop

Author	Prathmesh Humane (Intern ID 2414)
Organisation	RedKross Research Foundation, Internship Programme (October 2026 batch)
Task	Digital Forensics Basics
Submission deadline	25 October 2026
Repository	`digital-evidence-preservation-workflow` (see README)

Abstract

This project designs a first-responder workflow for preserving digital evidence from a suspected compromised laptop. It also delivers a blank chain-of-custody template, a fully fictional worked example, and a practical SHA-256 hashing demonstration. The workflow was derived from established guidance (RFC 3227, NIST SP 800-86, NIST IR 8387, ISO/IEC 27037, the ACPO principles and SWGDE best practice) and adapted for non-specialist staff in a college or small organisation. It has nine steps.

Three points from the research shaped the design. The power-state decision is the single most consequential first-responder action. Disk encryption makes keeping the device powered more valuable. A file hash proves content integrity but not file-system metadata, so documentation remains essential. The practical demonstration tests five integrity properties on invented files.

1. Project Objective

The assigned task was to:

> Write a safe evidence-preservation workflow for a hypothetical compromised laptop. Cover recording observations, minimising unnecessary handling, documenting time and actions, protecting original evidence, hashes where appropriate, and chain of custody.

with deliverables: an evidence-handling guide, a blank chain-of-custody template, and one fictional worked example.

The specific objectives were:

1. Produce a workflow that a **non-specialist first responder** can follow without destroying evidence.
2. Make every recommendation traceable to a credible source.
3. Provide **ready-to-use** documentation tools: a printable and editable chain-of-custody form.
4. Show the workflow applied end-to-end in a **fictional** scenario.
5. Demonstrate, with a safe hands-on test, what hashing does and does not prove.
6. Stay within the safety constraint: **no data is collected from any other person's device**.

2. Background Research

2.1 Why digital evidence is fragile

Data on a running computer has different lifetimes. RFC 3227 orders evidence by volatility, from CPU registers and memory (lost in milliseconds or at power-off) to disks and archival media (persistent) [1]. NIST SP 800-86 adds that simply *examining* a live system changes it. Every command loads into memory and may write to disk [2]. A responder therefore faces a trade-off. Acting on the system can capture volatile data, but it also changes the system.

2.2 Standards and guidance reviewed

Source	Contribution to this project
RFC 3227, *Guidelines for Evidence Collection and Archiving* (2002) [1]	Order of volatility; collection principles; documentation
NIST SP 800-86 (2006) [2]	Forensic process (collection, examination, analysis, reporting); live-system cautions
ISO/IEC 27037:2012 [3]	International framework for identification, collection, acquisition and preservation
ACPO *Good Practice Guide for Digital Evidence* v5 (2012) [4]	Four principles: don't change data, competence, audit trail, responsibility
SWGDE *Best Practices for Digital Evidence Collection* (2018) [5]	Treat sleeping devices as on; leave powered-off devices off; network isolation; forced power-off when destruction is observed
NIST IR 8387 (2022) [6]	Hash with NIST-approved algorithms as close to collection as possible; store hashes where they cannot be altered; keep multiple verified copies
NIST SP 800-61 Rev. 3 (2025) [7]	Places evidence handling within the wider incident-response lifecycle (CSF 2.0)

2.3 Key concepts

- **Contemporaneous notes:** records made at the time of each action. They form the audit trail required by ACPO Principle 3 [4].
- **Write blocking:** hardware or software that allows a storage device to be read without any write reaching it. It is used during imaging.
- **Cryptographic hashing:** a one-way function producing a fixed-length digest. SHA-256 is specified in FIPS 180-4 [8]. MD5 and SHA-1 have practical collision attacks, and NIST is retiring SHA-1 [9]. NIST IR 8387 still allows older algorithms where needed, but prefers newer ones [6].
- **Chain of custody:** the documented, unbroken history of who held an item, when, where and why.

2.4 Indian legal and regulatory context

- **Bharatiya Sakshya Adhiniyam, 2023 (BSA), Section 63:** electronic records submitted as evidence need a certificate in the prescribed form, which includes the record's hash value. In May 2026 the Supreme Court declined a challenge to Section 63(4) and described the hash value as an "electronic fingerprint" [10].
- **CERT-In Directions (28 April 2022):** certain entities must report specified cyber incidents to CERT-In within 6 hours of noticing them [11]. Accurate timestamps from first responders support this.

3. Methodology

The work followed five stages:

1. **Requirement extraction.** I broke the task statement into six required topics (observations, minimal handling, time/action documentation, protecting originals, hashing, chain of custody) and three deliverables.
2. **Source review.** I read the sources in Section 2.2 and noted each recommendation relevant to a first responder.
3. **Workflow design.** I organised the recommendations into a sequence a non-specialist could follow, and made the critical decision (power state) explicit as a table.
4. **Artefact creation.** I wrote the guide, the template (Markdown, DOCX and PDF), the worked example and the hash-demo script.
5. **Evaluation.** I ran a requirement-traceability check, a standards-alignment check, a scenario walkthrough and a practical hash demonstration (Section 7).

3.1 Key design decisions

Decision	Rationale	Source
Write for **first responders**, not examiners	The task asks for a "safe" workflow. The safest contribution from a non-specialist is restraint plus documentation.	[2], [4]
Keep a powered-on laptop powered unless destruction is visible	Memory holds processes, connections and keys. With full-disk encryption (e.g. BitLocker), power-off can lock the disk.	[1], [5]
Forced power-off, not "Shut down", when power must be cut	Windows "Shut down" with Fast Startup writes hibernation data to disk	[5]
Prefer **network-side isolation**	Isolates the device without touching it	[5], [6]
No hashing on the live suspect device	Running any tool changes the system. Hashing the original happens during write-blocked imaging.	[2], [6]
SHA-256 as the primary algorithm	NIST-approved; MD5/SHA-1 only as secondary values	[6], [8], [9]
Record **time zone and device clock offset**	Lets examiners align device timestamps with network logs	[1], [4]
One custody form per item, with seal numbers and hash verification	Gives each item an independent, auditable history	[3], [6]
Fictional data only, with documentation IP ranges	Meets the safety constraint; avoids implying real systems	[12]

4. Tools and Technologies

Tool	Used for
Markdown and GitHub	Primary format for all documents (renders in the repository)
Pandoc and headless Chromium	Converting Markdown to PDF
`docx` (JavaScript library) and LibreOffice	Editable Word template and its PDF rendering
SVG	Workflow diagram (Figure 1 in the guide)

Tool	Used for
Bash, `sha256sum` / `shasum -a 256`	Hash demonstration script (macOS and Linux)
ShellCheck	Static analysis of the demo script
Git	Version control
Claude (Anthropic AI assistant)	Drafting support for documents and script. All content was reviewed and checked by the author against the cited sources.

5. Work Performed

Deliverable	Location	Description
Evidence-handling guide	`docs/evidence-handling-guide.md` / `.pdf`	Nine-step workflow, power-state decision table, network isolation, logging rules, packaging, hashing guidance, chain of custody, common mistakes, one-page checklist
Workflow diagram	`assets/workflow-diagram.svg`	Visual summary with the continuous action log
Blank chain-of-custody template	`templates/chain-of-custody-template.docx` / `.pdf` / `.md`	Sections A–F: case, item, collection, transfer log, hash record, disposition
Fictional worked example	`docs/worked-example-fictional.md` / `.pdf`	Full scenario: evidence register, photo log, power decision, action log with correction, hash record, completed custody form, hand-over summary
Hash demonstration	`lab/hash-demo/`	Script, reference hashes and instructions
Test evidence	`results/`	Demo output and screenshots
This report	`report/technical-report.md` / `.pdf`	—

6. Findings

1. **The power-state decision matters most.** Almost every irreversible loss in the sources comes from shutting down, restarting or interacting with a live machine. The guide therefore makes this a single table with three cases [1], [5].
2. **Encryption changes the default.** On modern laptops with disk encryption enabled, powering off can make the disk unreadable without the recovery key. This strengthens the case for keeping the device on and asking where the key is held, without ever recording the key itself.
3. **A hash proves content, not context.** A file's hash does not cover its timestamps. The hash demo confirms this (Test T4). Context must come from whole-disk imaging and from the responder's notes.
4. **Hashes need provenance.** A hash value is only useful if it is recorded at collection, stored where it cannot be altered, and checked at each transfer [6].
5. **Documentation is a technical control.** Clock-offset recording, single-line corrections and signed transfers cost little and determine whether evidence is trusted.
6. **"Where appropriate" has a concrete meaning.** Hash images and files you create or transfer. Never hash by running tools on the live suspect machine.

7. Testing and Evaluation

7.1 Requirement traceability

Task requirement	Guide	Template	Worked example
Recording observations	Step 2	Section C (photo refs, notes)	§4 photo log
Minimising unnecessary handling	Ground rules 1 and 3; Steps 3 and 4; Common Mistakes	—	§5, log 10:42–11:05
Documenting time and actions	Step 5	Time-zone instruction; Section D	§6 action log incl. clock offset and correction
Protecting original evidence	Step 6	Section B (seals); Section D	Log 12:20–12:30; §8 seal history
Hashes where appropriate	Step 7	Section E	§7 hash record
Chain of custody	Step 8	Sections A–F	§8 completed form
Evidence-handling guide	✔		
Blank chain-of-custody template		✔	
One fictional worked example			✔
No data from another person's device	§2 scope	Instruction box	Disclaimer; fictional data only

Result: every required topic and deliverable is covered in at least one artefact. The six workflow topics are each covered in all three.

7.2 Standards alignment

Guide step	ACPO [4]	RFC 3227 [1]	ISO/IEC 27037 [3]	NIST [2], [6]
1 Secure scene	P1	✔	Identification	SP 800-86 collection
2 Observe and record	P3	✔	Identification	—
3 Power state	P1, P2	Order of volatility	Collection	SP 800-86 live data
4 Isolate network	P1	✔	Collection	IR 8387 radio isolation
5 Action log	P3	✔	All stages	—
6 Protect original	P1	✔	Preservation	IR 8387 storage
7 Hashing	P3	✔	Acquisition, preservation	IR 8387 hashing
8 Chain of custody	P3, P4	✔	Preservation	IR 8387 transfers
9 Hand over	P4	✔	—	SP 800-61r3

7.3 Practical hash demonstration

Purpose. To test five integrity properties that the guide relies on, using only invented files.

Procedure. Run `lab/hash-demo/hash_demo.sh` as described in `lab/hash-demo/README.md`. The script creates three fictional files and runs tests T1–T5. It records a timestamped action log, and it hashes that log at the end.

Development checks (Linux build environment, before the author's run). The script passed ShellCheck static analysis. It was run three ways: as a normal user with `sha256sum`, as a normal user with only `shasum` available (the macOS code path), and as root. All five tests produced the expected results in the first two runs. As root, T2 was **skipped by design**, because root ignores file permissions. These checks show that the script works as written. They are not the author's test results, which are reported below.

Author's test environment.

Item	Value
Date and time of run (UTC and local)	**[TO FILL AFTER YOUR RUN: from Step 0]**
Operating system and version	**[TO FILL AFTER YOUR RUN]**
Hash tool	**[TO FILL AFTER YOUR RUN: `shasum -a 256` or `sha256sum`]**
Run folder	**[TO FILL AFTER YOUR RUN: `results/hash-demo-run-…`]**

Results.

Test	What was tested	Expected	Observed	Evidence
T1	Hashes match reference values	MATCH	**[TO FILL]**	`02-reference-match.png`
T2	Read-only original blocks writes	PROTECTED	**[TO FILL]**	`03-readonly-protected.png`
T3	Working copy verifies against original	VERIFIED	**[TO FILL]**	`04-copy-verified.png`
T4	Timestamp-only change leaves hash unchanged	HASH UNCHANGED	**[TO FILL]**	`05-timestamp-same-hash.png`
T5	One-character change detected	DETECTED	**[TO FILL]**	`06-tamper-detected.png`

Sealed action-log hash (Step 7): **[TO FILL AFTER YOUR RUN]**

Interpretation. [TO FILL AFTER YOUR RUN: one short paragraph, e.g. whether all tests met expectations and what T4 and T5 show about the guide's advice.]

7.4 Scenario walkthrough

The fictional worked example was checked against the guide's one-page checklist (Section 9 of the guide). All 12 checklist items are addressed:

Checklist item	Where in example
Authority recorded	§8 A (Dr M. Rao, 10:30)
Scene secured; reported actions recorded	Log 10:38–10:39
Photos	§4, P-01 to P-10
Power state and reason	§5
Encryption status; key not recorded	§5, log 10:43
Network isolated, minimal interaction	Log 10:45–10:46
Clock offset	§6 clock note
Contemporaneous, signed log	§6 (including correction)
Items labelled, bagged, sealed	§3, log 12:20–12:25
SHA-256 recorded	§7

Checklist item	Where in example
Custody forms; signed hand-offs	§8 D
Hand-over summary; escalation	§9

The walkthrough also exposed a realistic difficulty: a locked screen when memory capture is needed. The example handles it by recording an authorised, witnessed unlock as a change to system state, which is consistent with ACPO Principle 2 [4].

8. Limitations

- **No expert or field validation.** The workflow has not been reviewed by a certified forensic examiner or tested in a live exercise.
- **Fictional scenario.** The worked example shows procedure, not real-world timings or complications.
- **Generalised guidance.** Organisation policy, legal requirements and jurisdiction may require changes. This project is not legal advice.
- **Hash demo scope.** It tests file-level hashing on small text files. `chmod` is a teaching stand-in for hardware write blocking and does not stop an administrator.
- **Out of scope.** Memory capture, imaging and analysis tools were not evaluated. Mobile, cloud and server evidence are not covered.
- **Source age.** Some core guidance is older (SP 800-86, 2006; ACPO, 2012; SWGDE collection, 2018). Newer sources (IR 8387, SP 800-61r3) were used to cross-check it.

9. Recommendations

1. Run a **tabletop exercise** with IT staff, using the worked example as the script, and refine the guide from what goes wrong.
2. Ask a **qualified examiner** to review the power-state table against local tools and policy.
3. Prepare a **first-responder kit** with pre-printed custody forms and pre-numbered tamper-evident seals.
4. Make sure **disk-encryption recovery keys are escrowed** centrally, so the "keep powered" decision does not depend on luck.
5. **Synchronise endpoint clocks** (NTP) to reduce clock offsets and simplify timelines.
6. Extend the workflow to **mobile devices and cloud accounts** in a later version.

10. Conclusion

The project delivers a practical, source-backed workflow that turns a stressful moment into a sequence of safe actions: secure, record, decide the power state, isolate, log, protect, hash where appropriate, record custody, and hand over. The template and worked example make it immediately usable. The hash demonstration provides practical evidence for the guide's key technical claims, and the report records honestly which parts were tested and which were not.

References

[1] D. Brezinski and T. Killalea, "Guidelines for Evidence Collection and Archiving," RFC 3227 / BCP 55, IETF, Feb. 2002. https://www.rfc-editor.org/rfc/rfc3227

[2] K. Kent, S. Chevalier, T. Grance and H. Dang, *Guide to Integrating Forensic Techniques into Incident Response*, NIST SP 800-86, Aug. 2006. https://doi.org/10.6028/NIST.SP.800-86

[3] ISO/IEC 27037:2012, *Information technology: Security techniques: Guidelines for identification, collection, acquisition and preservation of digital evidence*. https://www.iso.org/standard/44381.html

[4] Association of Chief Police Officers (ACPO), *Good Practice Guide for Digital Evidence*, Version 5, Mar. 2012.

[5] Scientific Working Group on Digital Evidence (SWGDE), *Best Practices for Digital Evidence Collection*, 18-F-002, Version 1.0, July 2018. https://www.swgde.org/documents/published-complete-listing/18-f-002-swgde-best-practices-for-digital-evidence-collection/

[6] B. Guttman, D. R. White and T. Walraven, *Digital Evidence Preservation: Considerations for Evidence Handlers*, NIST IR 8387, Sept. 2022. https://doi.org/10.6028/NIST.IR.8387

[7] A. Nelson, S. Rekhi, M. Souppaya and K. Scarfone, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*, NIST SP 800-61 Rev. 3, Apr. 2025. https://doi.org/10.6028/NIST.SP.800-61r3

[8] NIST, *Secure Hash Standard (SHS)*, FIPS PUB 180-4, Aug. 2015. https://doi.org/10.6028/NIST.FIPS.180-4

[9] NIST, "NIST Retires SHA-1 Cryptographic Algorithm," news release, Dec. 2022. https://www.nist.gov/news-events/news/2022/12/nist-retires-sha-1-cryptographic-algorithm

[10] "Supreme Court Rejects Challenge To S.63(4) BSA Mandating Hash Value Disclosure For Electronic Evidence," *LiveLaw*, May 2026. https://www.livelaw.in/top-stories/supreme-court-rejects-challenge-to-s63 4-bsa-mandating-hash-value-disclosure-for-electronic-evidence-535950

[11] CERT-In, Directions under sub-section (6) of Section 70B of the Information Technology Act, 2000, No. 20(3)/2022-CERT-In, 28 Apr. 2022. https://www.cert-in.org.in/

[12] J. Arkko, M. Cotton and L. Vegoda, "IPv4 Address Blocks Reserved for Documentation," RFC 5737, IETF, Jan. 2010. https://www.rfc-editor.org/rfc/rfc5737